Computer Forensics

Acknowledgement

- **Cyber Security** by Nina Godbole, Sunit Belapure, Wiley India

Digital Forensics Life Cycle

- **Digital evidence** is present in nearly every crime scene.
- The law enforcement must know how to **recognize, seize, transport and store** original digital evidence to preserve it for forensics examination.
- Cardinal rules to remember are that **evidence:**
  - Is admissible
  - Is authentic
  - Is complete
  - Is reliable
  - Is understandable and believable

Digital Forensics Life Cycle

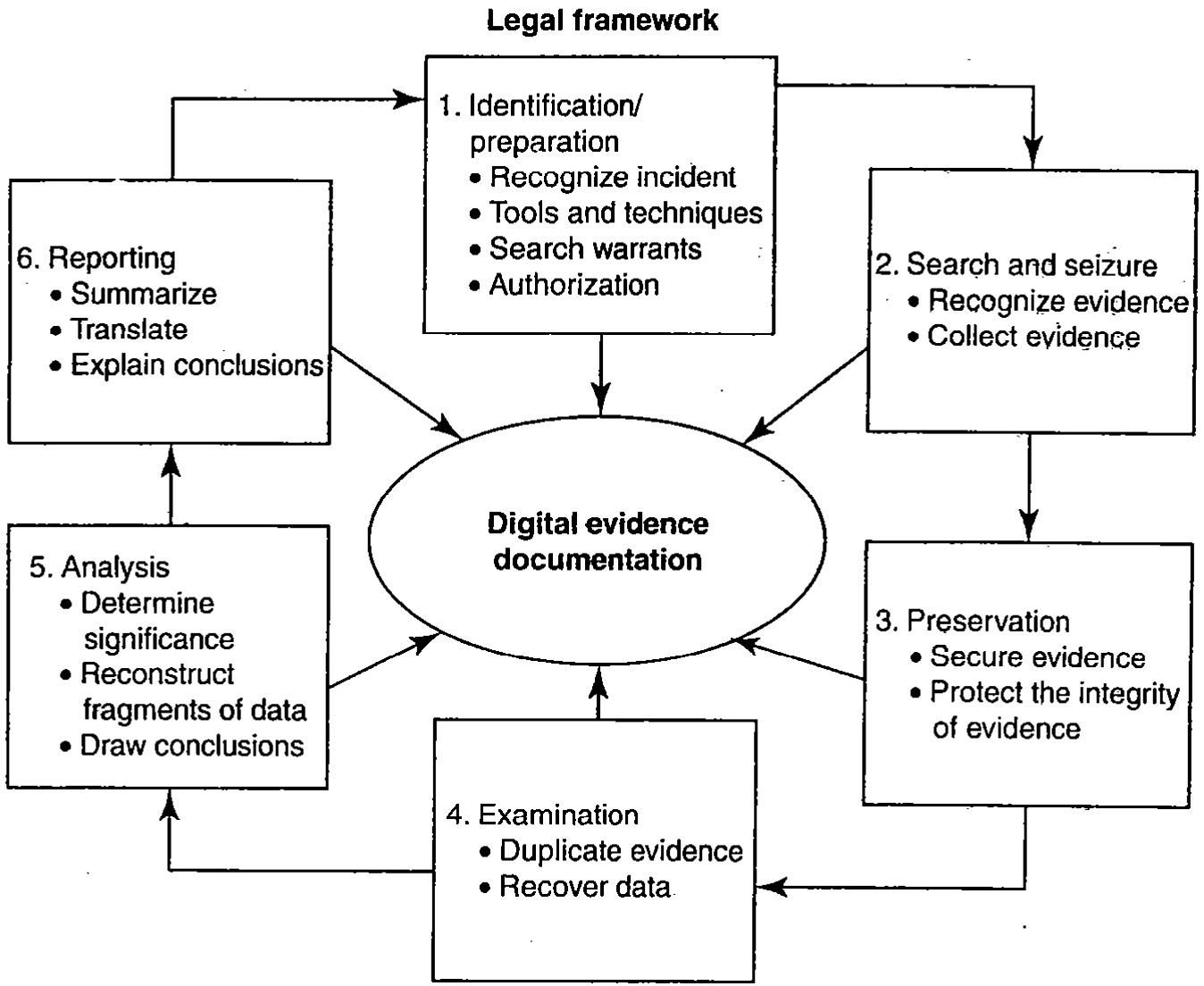


Figure 7.5 | Process model for understanding a seizure and handling of forensics evidence legal framework.

The Digital Forensics Process

- The **digital forensics process** needs to be understood in the **legal context** starting from **preparation** of the evidence to **testifying**.
- Digital forensics evidence consists of **exhibits presented by witnesses** in a legal matter to help jurors establish the facts of the case and support or refute legal theories of the case.
- The **exhibits** should be **introduced and presented and/or challenged by properly qualified people**.

The Digital Forensics Process

- The **exhibits** are introduced **as evidence by either side**.
- Testimony (formal written or spoken statement) is presented to **establish the process to identify, collect, preserve, transport, store, analyze, interpret, attribute, and/or reconstruct the information contained in the exhibits and to establish that the evidence reflects a sequence of events that is asserted to have produced it.**
- The party must **show not only the evidence** to be admitted but must also **establish that the evidence is relevant, authentic** and that the evidence presented is **not the result of hearsay and more probative than prejudicial**.

The Digital Forensics Process

- The **testimony** would include the processes used for **creating, handling and introducing the evidence, the method used for collecting the exhibit** as well as the manner in which the exhibits is **brought to court**.
- **Digital forensics evidence** is usually latent, that is, "**hidden**" in that it can **only be seen** by the trier of fact at the desired level of details **through the use of tools**.

The Digital Forensics Process

- Digital forensics evidence **can be challenged** by establishing that, by intent or accident, **content, context, meaning, process, relationships, ordering, timing, location, corroboration and/or consistency** are made or missed by the **other side**, and that this **produced false positives or false negatives** in the results presented by the **other side**.

The Digital Forensics Process

- Once the forensics experts know the landscape of the computers and other artifacts involved, they formulate a **cost proposal** governing all needed activities in the **forensics search and analysis**.
- This is combined with a **proposed timeline** of activities, list of anticipated **deliverables** and a **plan** for production and turnover of evidence.
- Forensics experts also submit a **preliminary risk analysis** for the forensics service being proposed.

The Digital Forensics Process

- For forensics **findings** of any type to be used as **admissible evidence** in court, the **data acquisition**, also known as "**imaging**", of the subject computers must be flawless and defensible in substance and technique.
- Forensics examiners are **trained to follow** a carefully developed **set of protocols** for **acquisition** of electronic evidence designed to ensure **authenticity** and diligent **chain of custody**.

The Phases in Computer Forensics / Digital Forensics

- **Tools that are used to generate reports for court should be validated**.
- Forensics life cycle involves the following **phases**:
  - Preparation and identification
  - Collection and recording
  - Storing and transporting
  - Examination/investigation
  - Analysis, interpretation and attribution
  - Reporting
  - Testifying

The Phases in Computer Forensics / Digital Forensics

- The process involves the following activities:
  - **Prepare:** Case briefings, engagement terms, interrogatories, spoliation (ruining or destroying), prevention, disclosure and discovery planning, discovery requests
  - **Record:** Drive imaging, indexing, profiling, search plans, cost estimates, risk analysis
  - **Investigate:** Triage (priority) images, data recovery, keyword searches, hidden data review, communicate, iterate
  - **Report:** Oral vs. written, relevant document production, search statistics reports, chain of custody reporting, case log reporting
  - **Testify:** Testimony preparation, presentation preparation, testimony

Preparing for the Evidence and Identifying the Evidence

- Every sequence of **events** within a single computer might **cause interactions with files and the file systems** in which they reside, **other processes and the programs** they are executing and the files they produce and manage, and log files and audit trails of various sorts.
- In a **networked environment**, this extends to all **networked devices**, potentially all over the **world**.
- Digital forensics evidence might be contained in a **time stamp** associated with a different program in a different computer on the **other side of the world that was offset** from its usual pattern of behavior by a few microseconds.

Collecting and Recording Digital Evidence

- Digital evidence can be **collected from sources** that include Computers, cell phones, digital cameras, hard drives, CD-ROM, USB memory devices etc.
- **Non-obvious sources** include settings of digital thermometers, black boxes inside automobiles, RFID tags and webpages
- **Calculate cryptographic hash of an evidence file and record that hash elsewhere to detect any change**
- **Collect volatile data** from the computer at the onset of the response
- Embedded **flash memory** – solid state non-volatile memory (used in USB stick, cell phones, digital cards, multimedia cards)

Storing and Transporting Digital Evidence

- Practices adopted in **handling** of digital evidence:
  - Image computer media using a **write-blocking tool**
  - Establish and maintain the **chain of custody**
  - Document everything that has been done
  - **Use tools and methods** that have been **tested and evaluated** to validate their accuracy and reliability

Storing and Transporting Digital Evidence

- Digital media must be properly **maintained for the period of time required** for the purposes of trial
  - Temperature and humidity controls
  - Supply additional power
  - Re-read media
- **Storage** must be adequately secure to assure proper "**Chain of Custody**"

Storing and Transporting Digital Evidence

- Digital forensics evidence can be **transported by making exact duplicates, at the level of bits**.
  - Includes movement of content over networks
- **Original copies are kept in a secure location**
- Adequate care must be taken in transportation to prevent spoliation (ruining or destroying)

Examining/Investigating Digital Evidence

- As a general rule, one **should not examine** digital information unless one **has the legal authority** to do so.
- **Dead Analysis**: **data at rest** e.g. content of hard drives
- **Live Analysis**:
  - Many current attacks against computer systems leave no trace on computer's hard drive
  - Attacker exploits information in the **computer's memory**
  - **Keys to decrypt** the storage is in **computer's memory**
  - **Turning OFF** the computer will cause that information to be **lost**

Examining/Investigating Digital Evidence

- Computer forensics software packages convert an entire hard drive into a **single searchable file** – this file is called as "**image**"
  - Tool: DCFLdd, Iximager or Guymager (bit stream copy)
- During imaging, a **write protection** device or application is used to ensure that no information is introduced onto the evidentiary media during forensics process
- The imaging process is **verified** by using SHA-1 message digest algorithm or other viable algorithms such as MD5

Analysis, Interpretation and Attribution

- Specialty **tools are used that can display information** in a format useful to investigators
  - Access Data's Forensics ToolKit
  - Guidance Software's EnCase
  - Dr. Golden Richard III's file carving tool Scalpel
  - Brian Carrier's Sleuth Kit
- Forensics analysis includes a **manual review of material** on the media
  - Windows registry inspection
  - Objective is to look for suspect information, discovering and cracking passwords, performing keyword searches for topics related to the crime, and extracting E-Mail and images

Analysis, Interpretation and Attribution

- As it is **not feasible to reconstruct every possible sequence** to investigate all the sequences that may have produced the actual evidence in any particular case, forensics analysis focus only on large sets of sequences of events.
- Analysis, interpretation and attribution of digital forensics evidence should be **reconciled with non-digital evidence**.
  - **Digital presence should be reconciled with physical presence**
- Open-source forensics tools
  - **Knoppix, Helix**
- Data held statically in an area of **RAM for long periods of time** are more likely to be **detectable**

Analysis, Interpretation and Attribution

- **Types of digital analysis**
  - **Media analysis**: data from a storage device. Doesn't consider any partitions or OS-specific data structures
  - **Media management analysis**: involve partitions, volume management or Redundant Array of Independent Disks (RAID)
  - **File system analysis**: Inside a partition or disk. To extract the contents of a file or to recover the contents of a deleted file.
  - **Application analysis**: Data inside a file. Files are created by users or applications.
  - **Network Analysis**: network packets examined using OSI Model to interpret the raw data into an application-level stream.
  - **Image analysis**: Information about where the picture was taken and who or what is in the picture. Examining images for evidence of steganography.
  - **Video analysis**: in security cameras and in personal video cameras and webcams. Used for identification of objects

Reporting

- Evidence, analysis, interpretation and attribution (inferring the causes of events) must be presented in the form of **expert reports, depositions (witness's sworn out-of-court testimony) and testimony**.
- Presentation of the report is more of an art than a science.

Reporting

- Broad-level **elements of the report**:
  - Identity of the reporting agency
  - Case identifier or submission number
  - Case investigator
  - Identity of the submitter
  - Date of receipt
  - Date of report
  - Descriptive list of items submitted for examination, including serial number, make and model
  - Identity and signature of the examiner
  - Brief description of steps taken during examination, such as string searches, graphics image searches and recovering erased files
  - Results/conclusions

Testifying

- Involves **presentation and cross-examination of expert witnesses**.
- **Digital forensics evidence is normally introduced by expert witness** except in cases where non-experts can bring clarity to non-scientific issues
- Expert witnesses address issues based on scientific, technical or other specialized knowledge.
- A witness qualified as an expert by knowledge, skill, experience, training or education may **testify in the form of an opinion**.
- **Expert** may in any event be required to **disclose the underlying facts or data on cross-examination**

Digital Forensics – phase-wise outputs

Table 7.5 | Digital forensics – phase-wise outputs

Phase	*Activities/Processes*	*Outputs*
Evidence Preparation and Identification	• Monitoring authorization and management support, and obtain authorization to do the investigation. • Ensuring that operations and infrastructure are able to support an investigation. • Providing a mechanism for the incident to be detected and confirmed. • Creating an awareness so that the investigation is needed (identify the need for an investigation). • Planning for getting the information needed from both inside and outside the investigating organization. • Identifying the strategy, policies and previous investigations. • Informing the subject of an investigation or other concerned parties that the investigation is taking place.	Plan Authorization Warrant Notification Confirmation

Digital Forensics – phase-wise outputs

Collection and Recording, Preserving and Transportation	• Determine what a particular piece of digital evidence is, and identifying possible sources of data. • Determine where the evidence is physically located. • Translating the media into data. • Ensuring integrity and authenticity of the digital evidence, for example, write protection, hashes, etc. • Packaging, transporting and storing the digital evidence. • Preventing people from using the digital device or allowing other electromagnetic devices to be used within an affected radius. • Recording the physical scene. • Duplicating digital evidence using standardized and accepted procedures. • Ensuring the validity and integrity of evidence for later use.	Crime type Potential Evidence Sources Media Devices Event

Digital Forensics – phase-wise outputs

Examination/ Investigation and Analysis, Interpretation and Attribution	• Determining how the data is produced, when and by whom. • Determine and validating the techniques to find and interpret significant data. • Extracting hidden data, discovering the hidden data and matching the pattern. • Recognizing obvious pieces of digital evidence and assessing the skill level of suspect. • Transform the data into a more manageable size and form for analysis. • Confirming or refuting allegations of suspicious activity. • Identifying and locating potential evidence, possibly within unconventional locations. • Constructing detailed documentation for analysis and drawing conclusions based on evidence found. • Determining significant based on evidence found. • Testing and rejecting theories based on the digital evidence. • Organizing the analysis results from the collected physical and digital evidence. • Eliminating duplication of analysis. • Build a timeline. • Constructing a hypothesis of what occurred, and comparing the extracted data with the target. • Documenting the findings and all steps taken.	Log files, file Events log Data Information

Digital Forensics – phase-wise outputs

Presentation and reporting	• Preparing and presenting the information resulting from the analysis phase. • Determine the issues relevance of the information, its reliability and who can testify to it. • Interpreting the statistical from analysis phase. • Clarifying the evidence and documenting the findings. • Summarizing and providing explanation of conclusions. • Presenting the physical and digital evidence to a court or corporate management. • Attempting to confirm each piece of evidence and each event in the chain either along with each other, or independent of one evidence and/or other events. • Proving the validity of the hypothesis and defend it against criticism and challenge. • Communicating relevant findings to a variety of audiences (management, technical personnel, law enforcement).	Evidence, Report

Digital Forensics – phase-wise outputs

Disseminating the case	• Ensuring physical and digital property is returned to proper owner. • Determining how and what criminal evidence must be removed. • Reviewing the investigation to identify areas of improvement. • Disseminating the information from the investigation. • Closing out the investigation and preserving knowledge gained.	Evidence Explanation New policies and investigation Procedures Evidence disposed Investigation closed

Precautions to be taken when Collecting Electronic Evidence

- Ensure that the evidence has been **accurately collected** and that there is a **clear chain of custody** right from the scene of the crime to the investigator and ultimately to the court.

Precautions to be taken when Collecting Electronic Evidence

- **Principle 1: No action taken** by law enforcement agencies or their agents **should change data** held on a computer or storage media, which may subsequently be relied upon in court.
- **Principle 2:** In exceptional circumstances, where a person finds it **necessary to access original data** held on computer or on storage media that **person must be competent** to do so and be able to give evidence explaining the **relevance and the implications of his/her actions**.

Precautions to be taken when Collecting Electronic Evidence

- **Principle 3:** An **audit trail or other record of all processes applied** to computer-based electronic evidence should be **created and preserved**. An independent **third party** should be able to **examine those processes** and achieve the same result.
- **Principle 4:** The person in-charge of the investigation has **overall responsibility** for ensuring that the law and these principles are **adhered** to.

Chain of Custody Concept

- Chain of custody is the central concept in Cyberforensics/digital forensics investigation.
- The **chain of custody is the process of validating** how many kinds of evidence have been **gathered, tracked and protected** on the way to a court of law.
- The **purpose of the chain of custody** is that the proponent (supporter) of a piece of evidence must **demonstrate** that it is what it purports (appears) to be.
- The chain of custody is a **chronological written record** of those individuals who have had custody of the evidence from its initial acquisition until its final disposition.

Chain of Custody Concept

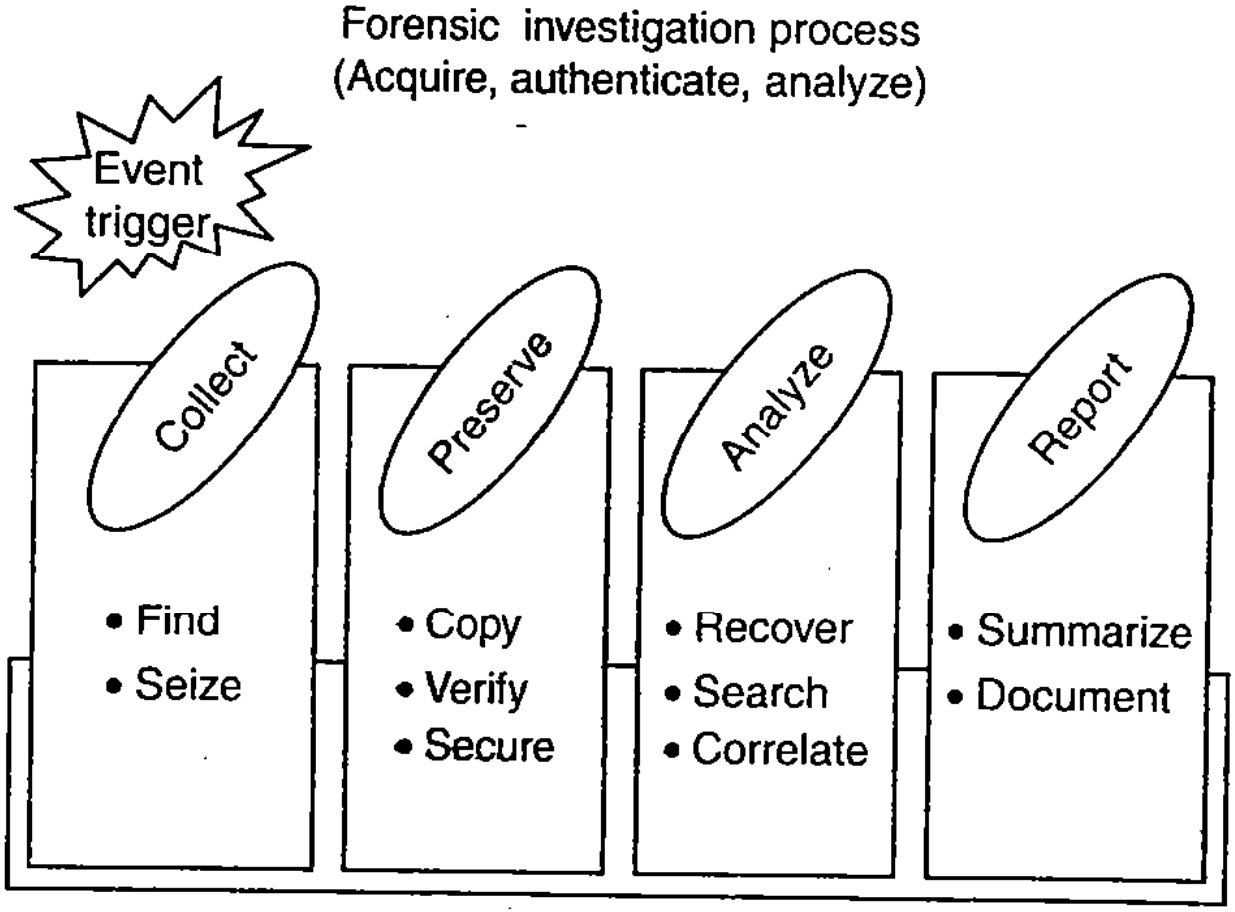


Figure 7.10 | Maintaining chain of custody – 1.

Chain of Custody Concept

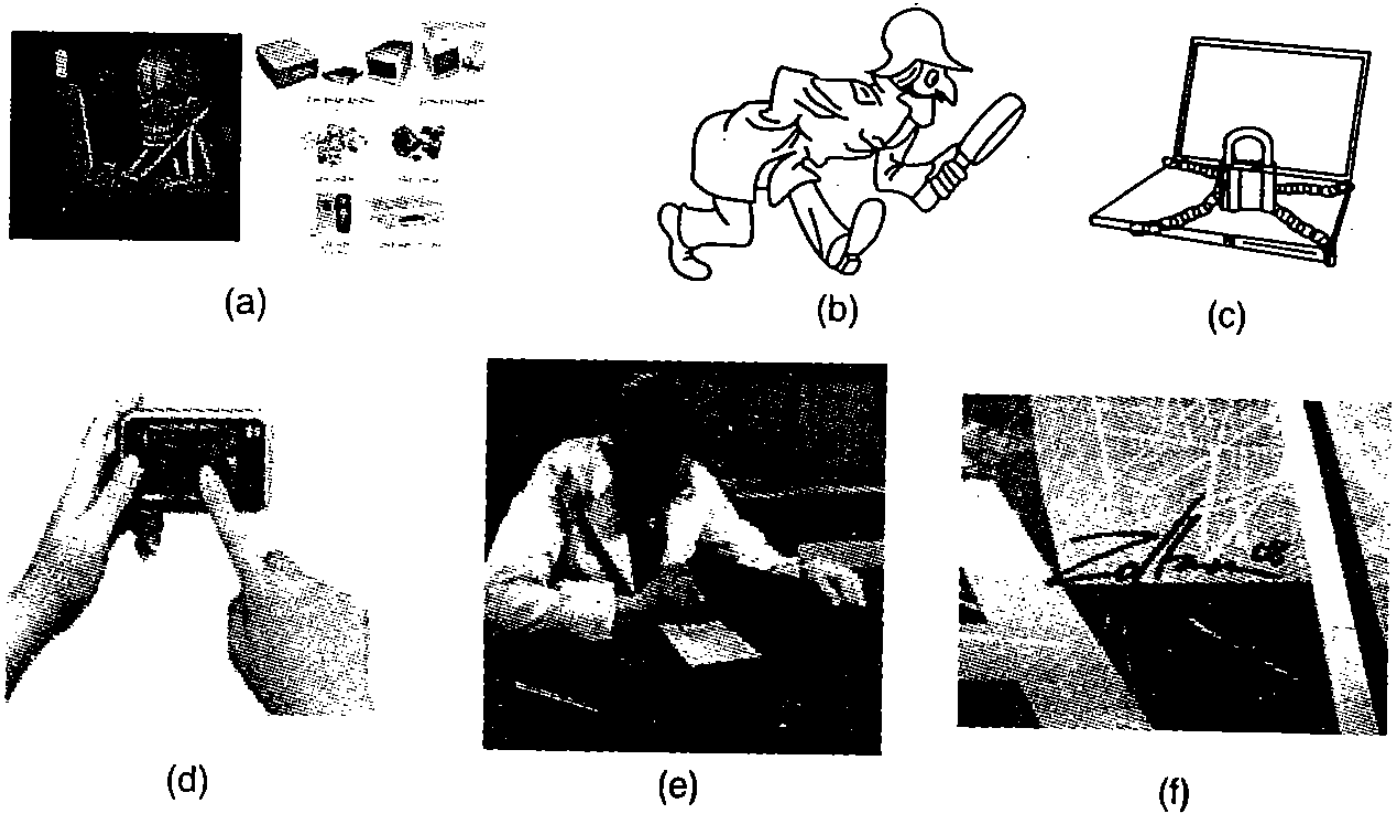


Figure 7.11 Maintaining chain of custody – 2. (a) Source of evidence – where did it come from? (b) Who found it? (c) Where was it stored/locked up? (d) Who touched it/tampered with it? (e) What did they do to it? What did they do with it? (f) Human signature is always required.

Network Forensics

- **Wi-Fi Internet** connection in the city continued to be **unprotected**.
- **Wireless forensics** is a discipline **included within the computer forensics science**, and specifically, within the **network forensics** field.
- The **goal** of wireless forensics is to **provide the methodology and tools required to collect and analyze (wireless) network traffic** that can be presented as valid digital evidence in a court of law.

Network Forensics

- The **wireless forensics process** involves **capturing** all data moving over Wi-Fi network and **analyzing** network events to **uncover network anomalies**, **discover the source of security attacks and investigate breaches on computers and wireless networks** to determine whether they are or have been used for illegal or unauthorized activities.

Approaching a Computer Forensics Investigation

- Broad **phases involved in the investigation** are:
  - **Secure** the subject system (from tampering or unauthorized changes during the investigation)
  - **Take a copy** of hard drive/disk (if applicable and appropriate)
  - **Identify and recovery** all files (including deleted files)
  - **Access/view/copy** hidden, protected and temporary files
  - **Study** "special" areas on the drive (e.g. residue from previously deleted files)
  - **Investigate** data/settings from installed applications/programs used on the system
  - Consider the **system as a whole**, including its structure and overall contents
  - Consider **general factors** relating to the user's computer and other **activity and habits** in the context of the investigation
  - Create detailed and considered **report**, containing an assessment of the data and information collected
- Full audit **log of activities** should be maintained

Approaching a Computer Forensics Investigation

- **Should be avoided** during investigation
  - Avoid changing date/time stamps (of files) or changing data itself
  - Avoid overwriting of unallocated space (which can happen on reboot)
- **Should not be avoided** before investigation
  - Engagement contract and non-disclosure agreement

Typical Elements Addressed in a Forensics Investigation Contract

- Authorization:
  - **Customer will be asked to authorize / facilitate** to conduct an evaluation
  - Customer is supposed to declare that the representations of information/data on said property or equipment are true and correct.
- Confidentiality:
  - The computer forensics **laboratory cannot disclose** confidential information except to its employees, consultants or subcontractors as needed for the sole purpose of performing the engagement.

Typical Elements Addressed in a Forensics Investigation Contract

- Payment:
  - Customer agrees to **pay all sums in advance** includes:
    - Charges for computer forensics laboratory services
    - Reasonable travel and per diem expenses for onsite work
    - Shipping and insurance and actual expenses
    - Media and software used in the forensics service engagement

Typical Elements Addressed in a Forensics Investigation Contract

- Consent and acknowledgement:
  - Any **consent** required of either party becomes effective only if **provided in a commercially reasonable manner**.
  - Customer **needs to acknowledge** that
    - Equipment/data/media **may be damaged prior to** computer forensics laboratory receipt
    - **Efforts of** computer forensics laboratory result in the **destruction of or damage to** the equipment / data / media

Typical Elements Addressed in a Forensics Investigation Contract

- Limitation of liability:
  - The computer forensics laboratory is **not liable for any claims** regarding the **physical functioning** of the equipment/media or the condition or existence of data stored on the media supplied before, during or after services.
  - The laboratory will **not be liable for any loss of data or loss of revenue or profit, goodwill or anticipated savings or any consequential loss**

Typical Elements Addressed in a Forensics Investigation Contract

- Any **advice or recommendation** given to the customer, which is **not confirmed in writing**, is followed or acted upon entirely at the **customer's own risk**.
- The customer has to agree **not to hold the forensics laboratory responsible for any accidental damages** to the data or equipments in its possession including but not limited to surface scratches, deformations and cracks.

Solving a Computer Forensics Case

- **Prepare** for the forensics examination
- **Talk to key people** to find out what you are looking for and what the circumstances surrounding the case are.
- **Start assembling your tools** to collect the data in question, Identify the target media.
- **Collect the data** from the target media. Create exact duplicate image of the device in question.
- To **extract the contents** of the computer in question, **connect the computer to a portable** hard drive or other storage media and then boot the computer. Use a **write-blocking tool** when imaging the media.

Solving a Computer Forensics Case

- When collecting evidence, be sure **check E-Mail** records as well.
- **Examine** the collected evidence on **the image** you have created. **Document anything that you find and where you found it**. Look for tools available both commercial products and open source products.
- **Analyze the evidence collected manually** looking into storage media and Check the registry, Internet searches, E-Mail and pictures.

Solving a Computer Forensics Case

- **Report your findings** back to your client. This report may end up as evidence in a court case.

Computer Forensics and Steganography

- **Steganography** is the art of **information hiding**.
- **Hiding messages in image data**, called steganography, is used by criminals and by noncriminals as will to send information over the Internet.
- **Cryptography is considered the predecessor of Steganography**.
- **Steganography** is considered as one of the "**antiforensics methods**".
- "**Computer antiforensics**" are methods of **removal and subversion of evidence with the objective to mitigate results** of computer forensics.
- Other methods are **encryption, self-splitting files plus encryption, database rootkits, BIOS rootkits, by passing integrity checkers**, etc.

Rootkits

- The term **rootkit** is used to describe the **mechanisms and techniques** whereby malware including viruses, Spyware and Trojans attempt to **hide their presence from Spyware blockers, antivirus and system management utilities**.
- Rootkits can be **classified as**
  - Persistent rootkits, memory-based rootkits, user-mode rootkits and kernel-mode rootkits

Rootkits

- A “rootkit” is a **set of tools used after cracking** a computer operating system that hides logins, processes, passwords, etc.
- Rootkits are **installed after an attacker has exploited a system vulnerability and gained root access**.
- **Rootkits** consists of tools that generally have **three functions**: **maintain** root access to the system, **hide** the presence of the attacker, **attack** against other systems.

Rootkits

- **Maintain root access to the system**
  - Via any **communication channel**
- **Hide the presence of the attacker**
  - By removing evidence of the compromise and taking measures to misrepresent the system state to curious or confused system administrators
  - **Cleaning various log files and temporarily disabling any monitoring demons**
  - Attacker **replace commonly used system executables, re-route system calls and install a loadable kernel module** in a single rootkit installation
- **Attack against other systems**
  - **Compromising** host security, **gathering** packet traces on local network, performing **vulnerability scans** or even **launching automated attacks** from the compromised host

Binary Rootkits

- **Binary rootkits take administrative utilities** and **modify them** to hide specific connections, processes and activities of specific users.
- These utilities would also include **tools to provide root access** to a particular user or when supplied with a particular arguments.
- When the binary tools are deployed, they are often **placed inside of a hidden directory** until the administrative programs can be fully compromised.

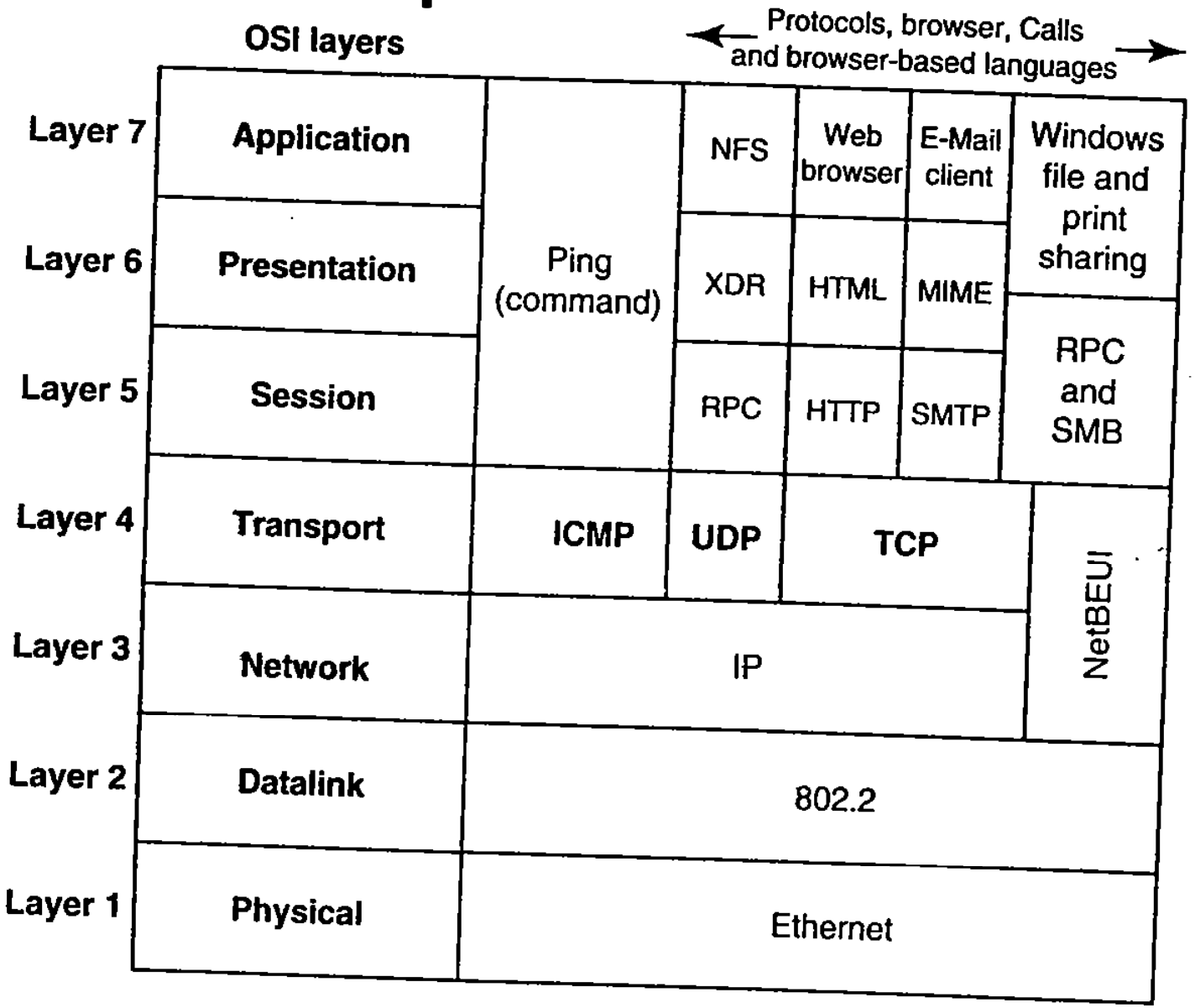
Binary Rootkits

- Binary rootkits **can be defeated through the use of file integrity scanners**.
- File integrity scanners work by **computing checksums, cryptographic checksums or even digital signatures**.
- File **signatures must be created when the system is in an uncorrupted state**
- Binary rootkits can also be **detected by system integrity tools**. However, certain commonly changed or temporary directories may be ignored by the system integrity scans.

Information Hiding

- Message can be hidden in images, sound files, text and other digital objects.
- Why one would want to hide information?
  - To **protect intellectual property**. Digital watermarks, digital fingerprints, serial number
  - To **convey information in a covert manner**. Steganography.
  - **Traces of criminal deeds do not fall in the hands of the investigator**. Data Sanitization (overwriting data that prevents recovery)

Relevance of the OSI 7 layer Model to Computer Forensics



Relevance of the OSI 7 layer Model to Computer Forensics

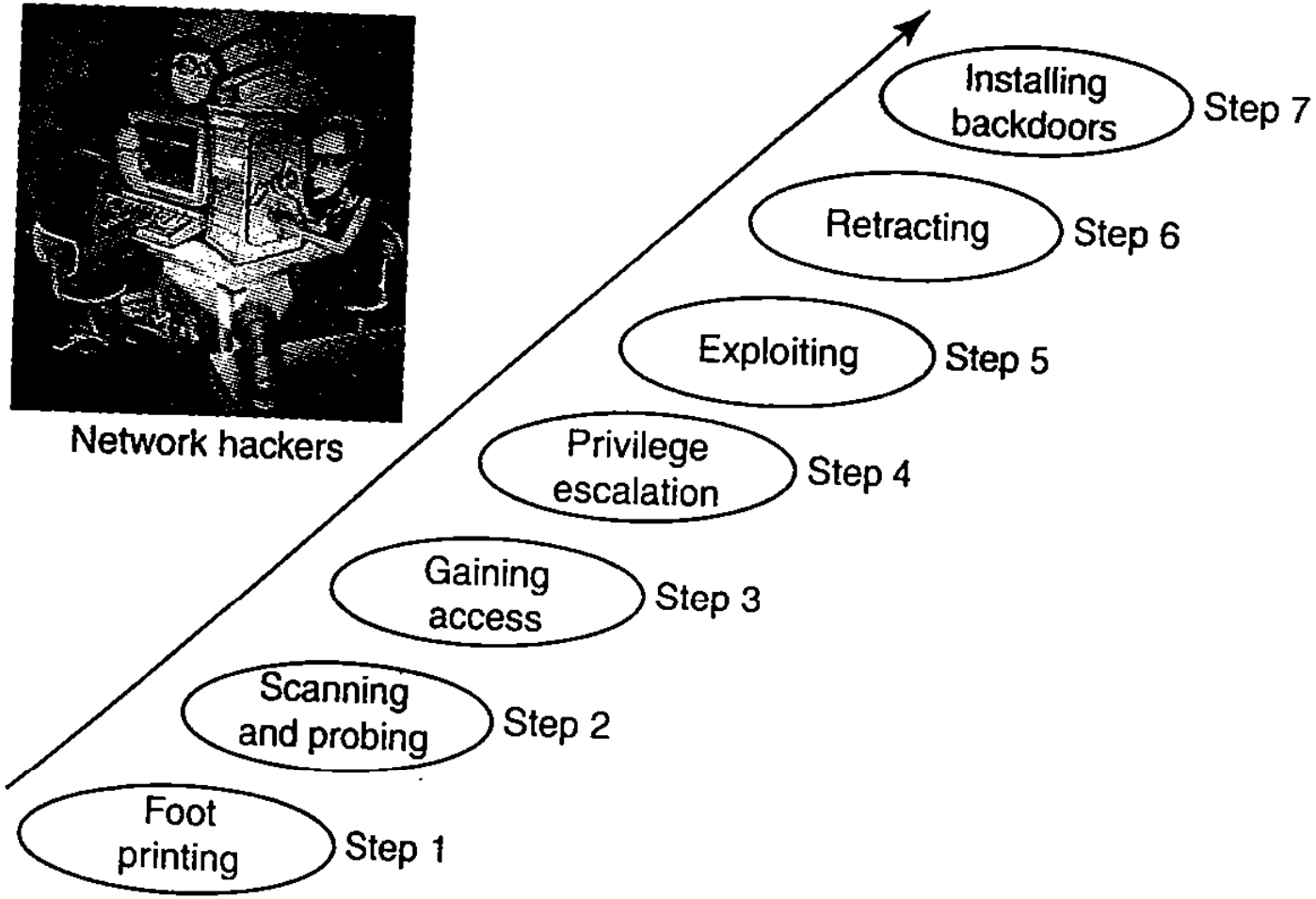


Figure 7.21 | Network hacking steps.
Note: This is being illustrated how hacking takes place.

Step 1: Foot Printing

- Includes **domain names, IP address and network blocks**
- Tools used: SamSpade, nslookup, traceroute and neotrace
- Hacker perform series of **scans or probes to gather more information** about individual machine for the purpose of gaining unauthorized access to the system
- These scans may include **ping sweeps, TCP/UDP scans and OS identification**
- Tool used: **Nmap**
- Tool called “Metasploit” used to perform penetration testing.

Step 2: Scanning and Probing

- Hacker will send a **ping echo request packet to a series of target IP address**
- **Echo response confirms a live machine** with that address
- **TCP scan sends TCP synchronization request to a series of ports**
- Using Nmap, the hacker can determine device type and OS details
- System scanning and probing can provide insights about the **easiest path into the targeted system** to a hacker

Step 2: Scanning and Probing

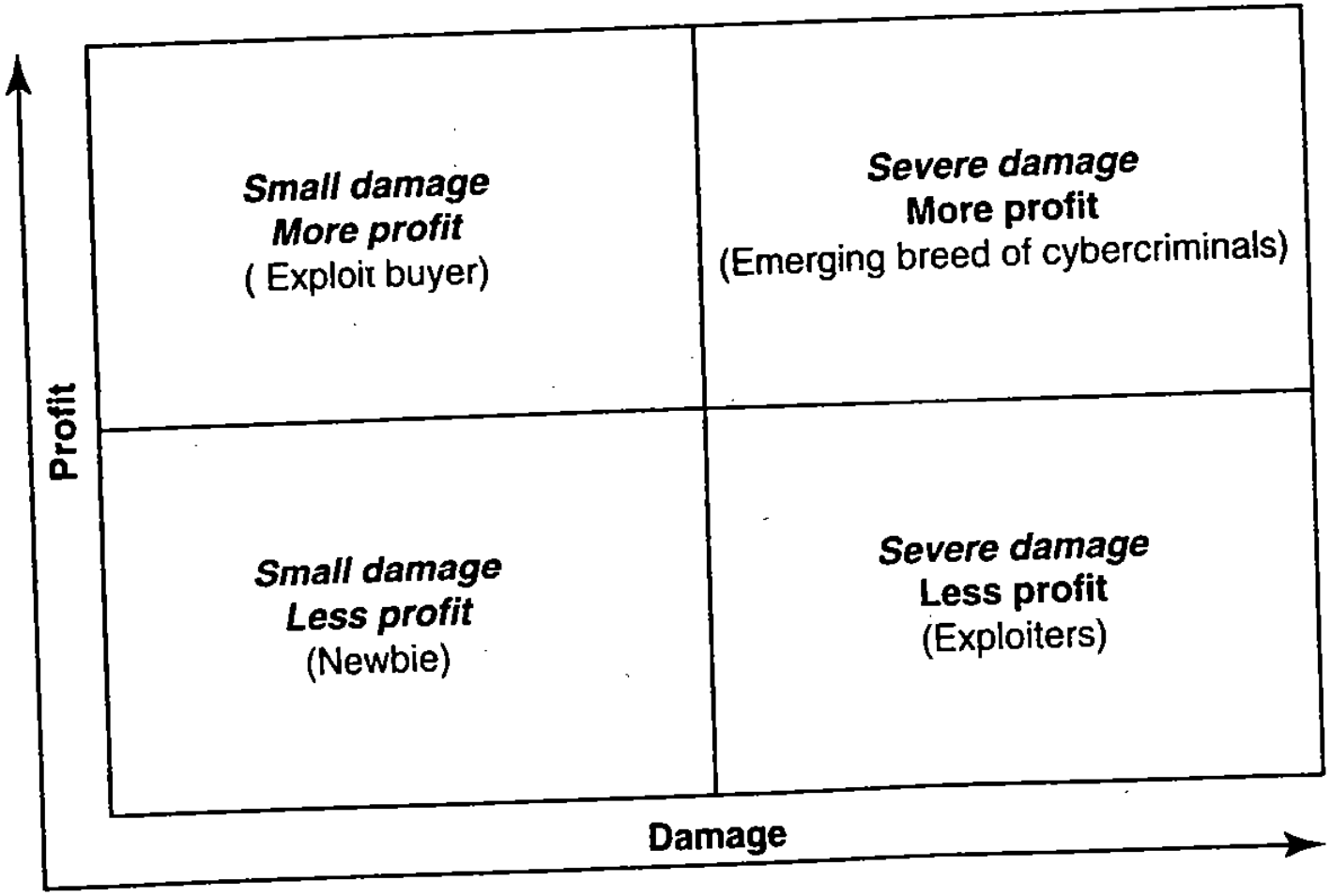


Figure 7.22 | Hacker categories (profit and damage).

Step 3: Gaining Access

- Gaining access takes advantage of specific **security weaknesses** in the system to allow access via an individual machine

Step 4: Privilege

- When a hacker gains access to the system, he will only have the privileges granted to the user or account that is running the process that has been exploited
- **An exploited application that is running under a root user will give the hacker immediate root access**
- Otherwise, the hacker must perform **additional actions to earn root access**.
- This entails trying to **crack passwords**

Step 5: Exploit

- Hackers, for fun or a challenge, **change a webpage or leave a "calling card"** to let his peers know that he/she was successful.
- Hackers try to **break into system to download valuable information and sell to other parties**, thereby gain financial rewards.
- There can be a disgruntled employee who may gain access to **sabotage an important project**.

Step 6: Retracting

- Hacker **take time and effort to modify system logs to hide his/her actions** and try to mislead forensics investigators that a crime has been committed.

Step 7: Installing Backdoors

- **Creating provisions for entry into the network / hacked system for later use**
- A **backdoor** is a **security hole deliberately left in place** to allow access from an uncommon/ unobvious path.

Forensics and Social Networking Sites: The Security/Privacy Threats

- A social networking site is defined as Web-based services that allow individuals to:
  - **Construct a public or semi-public profile** within a bounded system
  - Articulate a **list of other users with whom they share** a connection
  - **View and traverse their list of connections** and those made by others within the system
- **Content preservation can be challenging** given the dynamic, short-lived and often multi-format nature of social media.

Forensics and Social Networking Sites: The Security/Privacy Threats

- In order to collect and authenticate social networking content, there is a need for using tools.
- Essential to maintain robust **chain of custody documentation**

Forensics and Social Networking Sites: The Security/Privacy Threats

- Analyze and quantify the preserved forensics data to answer questions:
  - **Who posted** the offending content?
  - Is there a **"real live" person** to whom the offending content can be attributed even when evidence exists?
  - Can we identify the **time** frame associated with the posting of the offending content?
  - How much of the offending content **exists** across the entire social networking platform?
  - Is there **other evidence** that corroborates or supports interpretation of the relevant content?
  - How accurate is the reported **physical location**?

Forensics and Social Networking Sites: The Security/Privacy Threats

- The **aim of social networking site** is to design the site in such a way that encourages behavior to **increase both the number of users and their connections**.
- Privacy concerns:
  - **Facebook's Beacon service tracks activities** from **all users in third-party partner sites**, including people who never signed up with Facebook or who have deactivated their accounts
  - **Beacon sends back IP address, address of webpages the user visits**

Forensics and Social Networking Sites: The Security/Privacy Threats

- **Security issues** that are associated with social networking sites are:
  - Corporate espionage
  - Cross-site scripting
  - Viruses and worms
  - Social networking site aggregators
  - Spear Phishing and social networking specific Phishing
  - Infiltration of networks leading to data leakage
  - ID theft
  - Bullying
  - Digital dossier aggregation vulnerabilities, secondary data collection vulnerabilities, face recognition vulnerabilities
  - Content-based image retrieval (CBIR)
  - Difficulty of complete account deletion
  - Spam
  - Stalking

Forensics and Social Networking Sites: The Security/Privacy Threats

- Providing social networking site users with tools which will help **protect** them
  - Installation on user's computer to provide them the **ability to retrieve other online user information** via chat and social network websites
  - **Benefit law enforcement** in helping to **retrieve IP address, OS and the browser type**

Computer Forensics from Compliance Perspective

- Information security compliance requires the precise enforcement of policies and controls.
- **Big-4 laws**

The regulatory Perspective for Forensics at the International Level

1. Sarbanes Oxley Act (SOX):
   - The act was enacted to fight **corporate fraud**
   - The securities and Exchange Commission (SEC) is responsible for enforcement of SOX and all publicly traded companies must **report yearly** on the effectiveness of their financial controls.
   - Corporate Governance ensure that they have the proper **controls and audit processes in place to prevent and detect fraud**.
   - **Computer forensics is required to investigate fraud**
   - Computer forensics is the only precise and reliable method to determine **if digital records has been deleted and/or altered**.
   - It becomes essential for organizations **to have computer forensics capability anywhere and anytime in their organizations** to ensure compliance with SOX.

The regulatory Perspective for Forensics at the International Level

2. California SB 1386:
   - **Report security breeches** that result in the **unauthorized disclosure of a resident's private or financial information**
   - To **thwart identity theft and customer fraud**
   - Reasonable investigation of a security breach

The regulatory Perspective for Forensics at the International Level

3. Gramm-Leach Bliley Act (GLBA):
   - **Applies to financial organizations** or any organization that collects or transfers private financial information for the purpose of doing business or providing a service to its customers
   - **Financial Privacy Rule** addresses the **collection and dissemination of customers' information**
   - **Safeguards Rule** governs the **processes and controls in an organization to protect customers' financial data**
     - Ensures the **security and confidentiality** of customer information
     - Protect against any anticipated **threats or hazards** to the security or integrity of such information
     - Protect against **unauthorized access** to or use of such information that could result in substantial harm or inconvenience to any customer
     - **Response programs** that specify actions to be taken
     - **Intrusion Detection System response** by utilizing computer forensics investigations

The regulatory Perspective for Forensics at the International Level

4. HIPAA (Health Insurance Portability and Accountability Act of 1996):
   - Healthcare providers to improve the **privacy and security of their clients' medical information**
   - Includes **Information Security**
   - **Incident response policy**

The regulatory Perspective for Forensics at the International Level

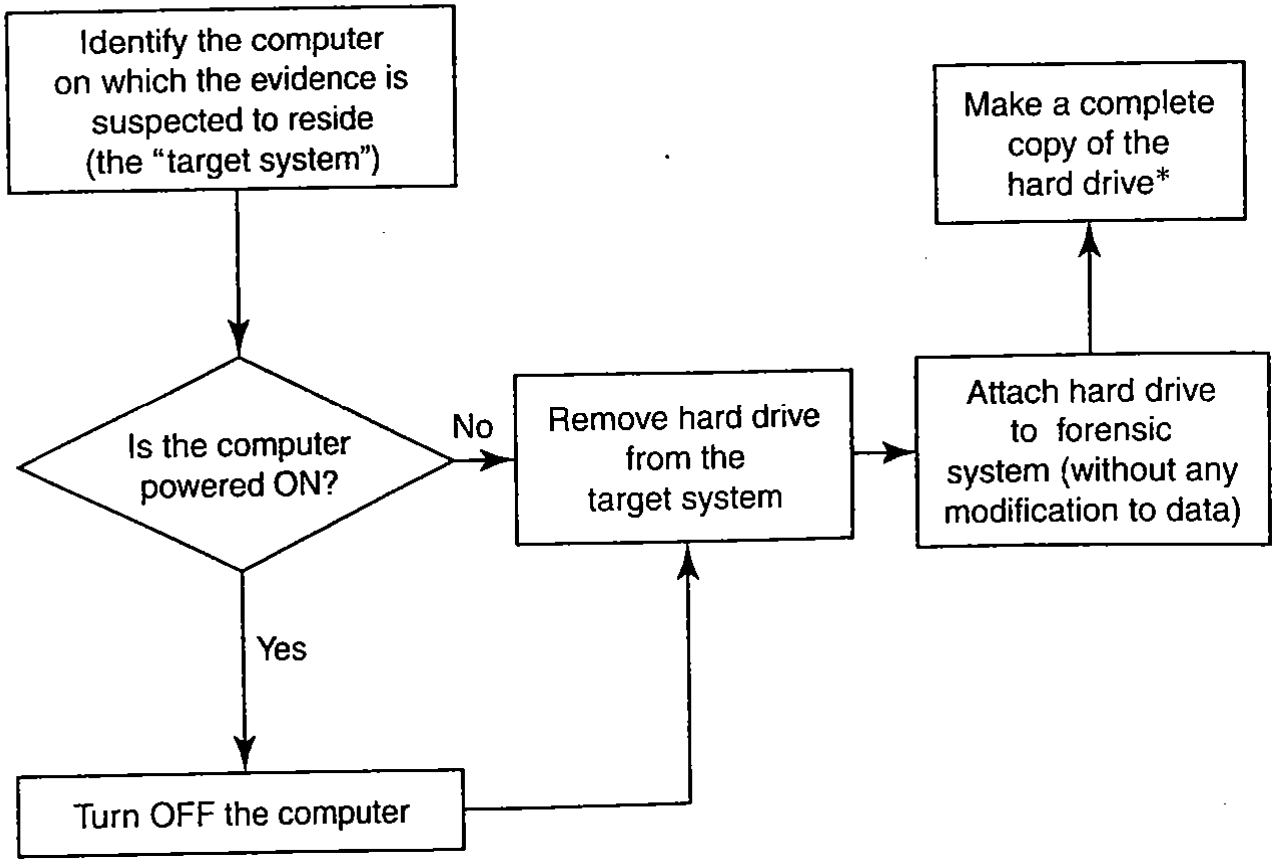


Figure 7.26 | Traditional approach to forensics analysis. *denotes tools/devices mentioned in Fig. 7.14.

The regulatory Perspective for Forensics at the International Level

- Key requirements of a sound forensics examination of digital evidence is that the **original evidence must not be modified**.
- Investigator should take care not to compromise the evidence.
- **Use write blocker**
- **Remote Forensics:** by placing a small read-only agent on the server, disk data and volatile system data can be accessed and imaged via the network

Computer Forensics Compliance Requirements: Implications for Evidential Aspects

- Organizations are turning to **logs to provide continuous trail** of everything that happens with their IT systems and their data
  - These logs offer situational awareness and thereby help organizations identify new threats as well as allow their effective investigation
- **Review and analysis of routine logs** are beneficial for identifying security incidents, policy violations, fraudulent activity and operational problems shortly after they have occurred, as well as for providing information useful for resolving such problems

Computer Forensics Expertise Status in India

- India seems to suffer from a two-fold problem:
  - **Lack of availability** of cyberforensics expertise
  - **Lack of awareness** about cyberforensics / digital forensics / computer forensics
- Reach of computer forensics must be **enterprise-wide**
- Response time should be **immediate**
- A combination of **in-house capability** supplemented with external **expert services**
- Cyberlaws of India need to be supported by **sound cybersecurity and effective cyberforensics**
- Need a good team of **techno-legal experts**

Challenges in Computer Forensics

- Billion **messages** sent and received per day, billion **indexed** webpages worldwide, billion **documents** online, **huge data stored** on tape or hard drives
- Existing tools and methods allow **everyone to alter any attribute** associated with digital data
- **Encryption is a major antiforensics technique** and **key word search can be defeated by renaming file names**

Challenges in Computer Forensics

- How to collect the specific, probative and case related information **from very large groups of files**?
  - Need to use approaches such as **link analysis and visualization**
  - **Enabling techniques for lead discovery** from very large groups of files. Look for **patterns**, called text mining and data mining

Challenges in Computer Forensics

- Network Forensics
  - Network may span **multiple time zones** and multiple jurisdiction
  - Network data will be available in both **offline and real-time modes**
  - Data could involve **different protocols**
  - Protocol could also involve **multiple layers of signal** (VoIP, HTTP tunnelling)

Challenges in Computer Forensics

- **Volume** of potential data to examine can create problem for law enforcement
- Many forensics matters do not go to trial
  - **Out-of-court settlement**
  - **Need-to-know basis**
- **Real-time data collection efforts are more complex** because they may need to address **legalities and privileges** involved in surveillance
- **Alterations to the digital media** that could occur when electronic device is turned **ON or OFF**, and inadvertent activation of **Trojan Horse or time-bomb malware** that was left behind **to corrupt data**

Technical Challenges: Understanding the Raw Data and its Structure

- A digital forensics investigator often faces the "complexity problem" because **acquired data is typically at the lowest and most raw format**
  - Layers of abstraction include ACII, HTML files, Windows Registry, Network Packets, Source Code
- "Quantity problem" involves the **hugeness** of digital forensics to analyze.
  - **Data reduction techniques** by grouping data into one larger event or by removing known data
  - Abstraction layers are **Identifying known network packets using IDS signatures, identifying unknown entries during log processing, identifying known files using hash database, sorting files by their type**

The Legal Challenges in Computer Forensics and Data Privacy Issues

- Digital evidence can be easily **duplicated and modified**
- **Failure to freeze** the evidence prior to opening the files
- **Locating the relevant evidence** within massive amounts of data
- The real challenges involve **artificial limitations imposed by constitutional, statutory and procedural issues.**

The Legal Challenges in Computer Forensics and Data Privacy Issues

- Personnel involved in digital forensics / computer forensics: **Technicians, Policy makers and Professionals**
- **Technicians** who carry out the technical aspects of **gathering evidence; Computer Hardware and Software**
- **Policy makers** establish forensics policies that **reflect broad considerations**
- **Professionals link between policy and execution**

The Legal Challenges in Computer Forensics and Data Privacy Issues

- **Skills** for digital forensics **professionals** are:
  - **Identify** relevant electronic **evidence** associated with violations of specific laws
  - Identify and articulate probable **cause necessary to obtain a search warrant** and recognize the limits of warrants
  - **Locate and recover** relevant electronic evidence **from computer systems** using tools
  - Recognize and maintain a **chain of custody**
  - **Follow a documented** forensics investigation process

The Legal Challenges in Computer Forensics and Data Privacy Issues

- The goal of detection and recovery is to recognize the digital objects that may contain information about the incident and document them
- "**Forensic acquisition of media**" mean the process of **making a bit-for-bit copy or image file** of a piece of media. Source of evidence must remain and not get altered.
- **Skills for Technicians** are understanding the various kinds of file systems, system software, data organization and specific OS.

The Legal Challenges in Computer Forensics and Data Privacy Issues

- Forensics investigator should understand that before they seize a computer or other electronic hardware they must **consider whether they require a search warrant**. Then they will need to **comply with the Privacy Act/Privacy Law** if applicable.
- In order to **conduct real-time electronic surveillance**, they will need to **obtain a wiretap order from a judge**.
- It is **difficult to perform a comprehensive decomposition and logging** of all materials (every sector of hard drive, thousands of hours of digital video), so a “scratch-and-sniff” approach might be used to yield promising information.

Special Tools and Techniques

- File carving (extracting data or reconstructing the file)
- Disk duplication
- Computer online Forensics Evidence Extractor
- Helix for incident response, system investigation and analysis, data recovery and security auditing

Digital Forensics Tools Ready Reckenor

The Coroner's Toolkit (TCT) Version 1.16 Visit www.porcupine.org	• OSS tool (open-source software) • No cost – OSS • Not a GUI-based product • Used with UNIX platform – it is a collection of command line tools • Written by Dan Farmer and Wietse Venema • Deep UNIX knowledge is the prerequisite to use TCT because it is a UNIX-only tool • Documentation is not detailed • Support to this tool is not much available – like most OSS tools, users are expected to fend for themselves
EnCase Forensics Version 5.0 Visit www.guidancesoftware.com	• GUI-based • Expensive • Adequate documentation • Simple to operate and use • Can acquire many different media • Plenty of web support • Costs around $3000 Targeted at large organizations

Digital Forensics Tools Ready Reckenor

Forensics Toolkit (FTK) Version 1.61 Visit www.accessdata.com	• Comprehensive with many features but not simple to use • Overwhelming program interface • Good documentation • Comes with a USB-pluggable hardware device • Costs around $1100
i2 Analyst's Noted Version 6.0.55 Visit www.i2inc.com	• Very different type of forensics analysis tool • Can import metadata from EnCase • Data can be imported from spreadsheet using CSV file • Has the ability to analyze complex crimes • Help system is very good • People-based support is expensive (online support and phone support is also available • Costs around $3700

Digital Forensics Tools Ready Reckenor

LogLogic's LX 2000 Visit www.loglogic.com	• Highly expensive – costs around $50000 • Excellent tool for log analysis – analyzes logs in real-time mode • Mature and useful product • High functionality but complex to set up • Excellent interface but high learning curve (many hidden features to be understood) • Adequate documentation
Mandiant First Respolnse Version 1.1 Visit www.mandiant.com	• No cost – freeware forensics audit tool with strong audit features • Not easy to use – awkward interface • Useful features once understood • Gathers forensics information in an organized and simple-to-read fashion • Limited support and limited documentation • Deploys agents across network computers to gather a snapshot before evidence is gathered

Digital Forensics Tools Ready Reckenor

NetWitness Version 6.0 Visit www.netwitness.com	• Network traffic security analyzer and works as a security intelligence tool. Helps automate IDS analysis process • Good user interface • Set up is easy due to installation wizard • Good user interface • Low scalability • Inadequate documentation • Web-based support and E-Mail-based support for registered users • Costs $30,000 • Not suitable for large enterprises
ProDiscover Incident Response Version 4.55 Visit www.techpathways.com	• Complete IT forensics tool can access computer over the network • Fairly easy to use • Supports remote analysis of running processes, open files, open port and services running on open ports • Not for first time users – experience in forensics required • Well laid-out documentation • Full disk imaging capability, ability to find hidden data, file metadata information, hash keeping as well as across network data gathering • Costs $8000

Digital Forensics Tools Ready Reckenor

Sleuth Kit and Autopsy Browser
Visit www.sleuthkit.org

- No cost – it is a freeware
- Good documentation
- Good support
- Straightforward to use for those familiar with UNIX environment but difficult to use by those not familiar with UNIX
- Can use Non-UNIX file systems too
- The browser can run on any HTML environment
- Adequate documentation
- Support is much better as compared to many other OSS – E-Mail-based support is available and many active user forums are available

Special Technique: Data Mining used in Cyberforensics

- Law enforcement agencies across the world compile **crime statistics**
- Traditional data mining techniques such as association analysis, classification and prediction, cluster analysis and outlier analysis identify patterns **in structured data**
- Newer techniques **identify patterns from both structured and unstructured data**
- Automated data mining techniques being researched for both local law enforcement and national security applications

Special Technique: Data Mining used in Cyberforensics

- Entity extraction
  - To **identify patterns from data** such as text, images or audio materials
  - Used to **automatically identify persons, address, vehicles and personal characteristics** from police narrative reports
  - In computer forensics, the extraction of software information such as the **data structure, program flow, organization and quantity of comments, and use of variable names**, can facilitate further investigation by **grouping similar programs written by hackers** and tracing their behaviour
  - Entity extraction technique **provides basic information** for crime analysis

Special Technique: Data Mining used in Cyberforensics

- Clustering techniques
  - Involves **grouping data items into classes with similar characteristics** to maximize or minimize interclass similarity
  - The **statistics-based concept space algorithm** is used to automatically associate different objects such as persons, organizations and vehicles in crime records
  - The Financial Crimes Enforcement Network AI System uses **link analysis techniques** to exploit bank secrecy act data to support the **detection and analysis of money laundering and other financial crimes**
  - The technique of **"clustering" crime incidents** can automate a major part of crime analysis

Special Technique: Data Mining used in Cyberforensics

- Association rule mining
  - Discovers **frequently occurring item sets** in a database and **presents the pattern as rules**.
  - Applied to **detect network intrusion** and to derive association rules from users' interaction history
  - Apply this technique to network intruders' profile to help detect potential future network attacks

Forensics Auditing

- **Forensics Auditing** is also known as **Forensics Accounting**
- Forensics Auditing includes the steps needed to **detect and deter fraud**
- **Forensics Accounting is a specialized form of accounting; it uses accounting, auditing and investigative techniques**
- Forensics Accounting professionals are assigned speciality tasks, such as **analyzing and tracking evidence of economic transactions, and to present this evidence to a court of law**
- Forensics auditors are responsible for **detecting fraud, identifying individuals involved, collecting evidence, presenting the evidence in criminal proceedings, etc.**
- There is an increasing use of **auditing skills to prevent fraud** by identifying and rectifying situations that could lead to frauds being perpetrated (i.e. risks)
- **Forensics auditing is either reactive or proactive**

Forensics Auditing

- The **Rules of Evidence** – "secure, auditable digital **date/time stamps**" will have the following **attributes**:
  - **Accuracy:** The time presented is from an authoritative source and is accurate precision required by the transaction, whether day/hour/ milliseconds
  - **Authentication:** The source of time is authenticated to a suitable timing library so that a **third party can verify** the precision and accuracy
  - **Integrity:** The time should be secured and not subjected to **corruption** during "handling."
  - **Non-repudiation:** An event or document should be **bound to its time** so that association between event or document and the time cannot be later denied
  - **Accountability:** The process of acquiring time, adding authentication and binding it to the subject event should be accountable

Forensics Auditing

- Using **secure and auditable time** helps to ensure that any important electronic time stamp that **cannot be corrupted has an evidentiary trail** of authenticity

Antiforensics

- **Antiforensics** is the application of scientific method to digital media to **invalidate factual information for judicial review**
- **Four categories of Antiforensics: data destruction, Data hiding, Data encryption, Data contraception** (prevent data from being stored on a disk)
- Antiforensics is a **combination of people, process and tools**
- **Counter-forensics software tools designed to eliminate specific records and files but leave system otherwise functional**

Antiforensics

- **Metasploit** antiforensics investigation arsenel includes tools such as **timestamp, slacker, transmogrify and sam juicer**
- Timestamp features include **display and set MACE attributes. Win32 system calls modify the Last Modified (M), Last Accessed (A), Creation Date (C) and Entry Modified (E)**. The examiner will use these values to attempt to piece together a **timeline of event**.
- The **attacker may modify these entries** then the examiner can not create a timeline for the crime committed.

Antiforensics

- **By a series of Win32 function calls, an attacker can place data at the end of a cluster**. A subsequent of series of function calls allow an attacker to retrieve the stored data.
- **Timestamp allows the criminal to hide information** on a system that may not be immediately distinguished **from other random slack space information**.
- **Little can be done examine hidden slack space information that has been properly obfuscated or encrypted**.

Antiforensics

- **Transmogrify is a simple search and replace engine** that allows for the file signatures to be changed between various types. An attacker might **change a JPG file to show up as a Windows Executable**.
- **Timestamp and transmogrify** are tools that focus **on changing, hiding or planting misleading evidence**.

Antiforensics

- "**Sam Juicer**" is designed to help advanced attackers **to prevent evidence from ever being created**. As a result, no evidence will ever come to disk and, therefore, a postmortem forensics analysis of the **disk will not reveal any clues** as to how the compromise occurred.

Antiforensics

- **Slaker** can **hide data within the slack space** of FAT or NTFS file system.
- **Slaker breaks a file into pieces and places each piece of that file into the slack space of other files**

Antiforensics

- **Data hiding technique involves the use of bad sectors**. The user **changes a particular sector from good to bad and then data is placed** onto that particular cluster.
- **Antiforensics is more than a technology**
- Antiforensics approach to criminal hacking is:
  - **Make it hard for them to find you and impossible for them to prove they found you**.